Seguridad en GenAI y LLMs: De la Vulnerabilidad a la Mitigación

6 de mayo de 2026

Índice

1. Introducción a la seguridad en GenAI y LLMs **2**
- 1.1. El problema del contexto unificado . . . 2
- 1.2. El vector de ataque semántico . . . 2
- 1.3. Necesidad de una Defensa en Profundidad . . . 2

2. Taxonomía de ataques: De Prompt Injection a Excessive Agency **3**
- 2.1. Prompt Injection y Jailbreaking (LLM01) . . . 3
- 2.2. Sensitive Information Disclosure (LLM02) . . . 3
- 2.3. Excessive Agency (LLM06) . . . 4
- 2.4. System Prompt Leakage (LLM07) . . . 4

3. Implicaciones éticas y legislativas de la vulneración de LLMs en producción **4**
- 3.1. El Marco Regulatorio: Reglamento (UE) 2024/1689 y RGPD . . . 5
- 3.2. Responsabilidad Civil y Supervisión Humana . . . 5
- 3.3. Integridad del Sistema y Mitigación de Sesgos . . . 5

4. Estrategias de mitigación técnica **6**
- 4.1. Alineamiento y Seguridad Intrínseca (RLHF) . . . 6
- 4.2. Ingeniería de Prompts Defensiva y Delimitadores . . . 6
- 4.3. Arquitectura de Guardrails (El Firewall Semántico) . . . 6
- 4.4. Filtrado Heurístico y Modelos de Clasificación . . . 7

5. Parte Práctica (Prueba de Concepto) **8**
- 5.1. Implementación de un agente LLM vulnerable (caso de uso simulado). . . . 8
- 5.2. Ejecución y documentación de ataques de inyección. . . . 8
- 5.3. Implementación de defensas (Guardrails). . . . 8
- 5.4. Evaluación comparativa de la robustez del sistema. . . . 8

6. Conclusiones **8**

7. Referencias bibliográficas **8**

1. Introducción a la seguridad en GenAI y LLMs

La integración de Modelos de Lenguaje Grande (LLMs) en entornos productivos ha introducido una vulnerabilidad estructural en la arquitectura de software: **la convergencia del plano de control y el plano de datos en una única interfaz.**

1.1. El problema del contexto unificado

A diferencia del desarrollo de software convencional, donde la entrada del usuario se trata como un flujo de datos inertes que se validan frente a esquemas rígidos (tipado fuerte, expresiones regulares o validación de esquemas JSON), los sistemas basados en LLM procesan la información de forma **monolítica**.

Dentro de la arquitectura **Transformer**, el *System Prompt* (instrucciones del desarrollador), el historial de la conversación y el *User Input* (entrada del usuario) se concatenan en una **ventana de contexto única**. Desde la perspectiva del motor de inferencia, no existe una distinción jerárquica o lógica entre estos componentes; todos son procesados como una secuencia de tokens. El modelo simplemente calcula la continuación más probable basándose en los pesos del mecanismo de atención (Vaswani et al., 2017). Si la entrada del usuario posee una carga semántica que contradice las instrucciones del sistema, el modelo puede priorizarla, provocando un secuestro del flujo de ejecución del agente.

1.2. El vector de ataque semántico

Las vulnerabilidades en LLMs se definen como **ataques semánticos**. A diferencia de una inyección SQL o un desbordamiento de búfer, donde se explotan fallos en la sintaxis o en el manejo de la memoria, aquí se explota la naturaleza probabilística del lenguaje natural.

El atacante no necesita romper el código fuente, sino manipular el contexto para que el modelo "razone" fuera de sus límites operativos. Esta superficie de ataque se expande críticamente cuando los modelos tienen capacidades de interacción con el mundo exterior, tales como:

- **RAG (Retrieval-Augmented Generation):** Donde una inyección indirecta puede provenir de un documento externo o base de datos vectorial.
- **Function Calling:** Donde el modelo traduce una instrucción en lenguaje natural a la ejecución de una API o código ejecutable.

1.3. Necesidad de una Defensa en Profundidad

Dada la fragilidad inherente del núcleo de los LLMs, la seguridad no puede depender únicamente del alineamiento interno del modelo (*Fine-tuning* o RLHF). Es imperativo implementar una estrategia de **Defensa en Profundidad** mediante capas de control externas.

El objetivo de este trabajo es analizar y demostrar cómo la implementación de **Guardrails** actúa como un "firewall semántico". Estas herramientas permiten interceptar la secuencia de tokens, tanto en la entrada como en la salida, para validar que el sistema se

mantiene dentro de los parámetros de seguridad y cumplimiento definidos, mitigando los riesgos de manipulación sin comprometer la utilidad del modelo.

2. Taxonomía de ataques: De Prompt Injection a Excessive Agency

El marco de referencia para clasificar las amenazas en aplicaciones de IA generativa es el **OWASP Top 10 for LLM Applications 2025** (OWASP Foundation, 2024). Este estándar actualiza los riesgos basándose en la integración de estos modelos en entornos productivos donde actúan como agentes con capacidad de ejecución.

2.1. Prompt Injection y Jailbreaking (LLM01)

Esta vulnerabilidad ocurre cuando las entradas del usuario alteran el comportamiento o la salida del LLM de formas no deseadas. Estas entradas pueden ser imperceptibles para los humanos siempre que sean procesadas por el modelo. Se distinguen dos tipos principales:

- **Inyección Directa:** El usuario manipula directamente el prompt para forzar al modelo a violar guías o generar contenido dañino.
- **Inyección Indirecta:** El modelo procesa información de fuentes externas (sitios web o archivos) que contienen instrucciones ocultas diseñadas para tomar el control del agente.

El *Jailbreaking* se define como una forma de inyección de prompt donde el atacante logra que el modelo ignore por completo sus protocolos internos de seguridad y ética. Además, la IA multimodal introduce riesgos nuevos, como instrucciones ocultas en imágenes que el modelo procesa concurrentemente con el texto.

2.2. Sensitive Information Disclosure (LLM02)

El modelo puede revelar inadvertidamente Información de Identificación Personal (PII), detalles financieros, registros médicos o datos comerciales confidenciales a través de sus salidas. Este riesgo no solo afecta a la privacidad, sino también a la propiedad intelectual, ya que pueden filtrarse algoritmos propietarios o código fuente. La mitigación técnica efectiva requiere:

- Aplicar técnicas de sanitización de datos antes de que la información entre al modelo de entrenamiento.
- Establecer políticas de términos de uso que permitan a los usuarios optar por no incluir sus datos en el entrenamiento del modelo.
- Implementar validación de entradas para filtrar datos sensibles antes de la inferencia.

2.3. Excessive Agency (LLM06)

Esta vulnerabilidad surge cuando se otorga a un sistema basado en LLM la capacidad de llamar a funciones o interactuar con otros sistemas mediante extensiones o herramientas. El problema reside en que el modelo puede decidir invocar una extensión de forma errónea ante prompts ambiguos o inyecciones. Las causas raíz suelen ser tres:

1. **Funcionalidad excesiva:** El agente tiene acceso a herramientas que no necesita para su operación (ej. permiso para borrar cuando solo debe leer).

2. **Permisos excesivos:** Las extensiones operan con identidades de alta jerarquía o permisos abiertos en bases de datos.

3. **Autonomía excesiva:** El sistema realiza acciones de alto impacto sin validación o aprobación humana (*human-in-the-loop*).

2.4. System Prompt Leakage (LLM07)

Se refiere al riesgo de que las instrucciones internas diseñadas para guiar el comportamiento del modelo contengan secretos o información sensible que sea descubierta por el usuario. OWASP enfatiza que el *System Prompt* no debe considerarse un secreto ni un control de seguridad en sí mismo. El riesgo fundamental no es la revelación del texto del prompt, sino los elementos subyacentes que expone, tales como claves de API, estructuras de roles, permisos o reglas de filtrado internas. Una vez que un atacante conoce estas reglas, puede diseñar ataques de escalada de privilegios o inyecciones más precisas para eludir los guardrails del sistema.

ID (2025)	Vulnerabilidad	Impacto Técnico
LLM01	Prompt Injection	Secuestro del flujo de ejecución del agente.
LLM02	Sensitive Info Disclosure	Exposición de PII, secretos y algoritmos.
LLM06	Excessive Agency	Acciones no autorizadas en sistemas externos.
LLM07	System Prompt Leakage	Revelación de la lógica interna y credenciales.

Tabla 1: Taxonomía de ataques actualizada según el estándar OWASP v2025.

3. Implicaciones éticas y legislativas de la vulneración de LLMs en producción

La seguridad en los modelos de lenguaje no es un factor accesorio, sino un requisito crítico de robustez y ciberseguridad para cualquier despliegue en entornos reales. La vulneración de

un sistema de IA trasciende el fallo técnico convencional, impactando directamente en la privacidad de los datos, el cumplimiento normativo y la integridad de los derechos fundamentales de las personas físicas.

3.1. El Marco Regulatorio: Reglamento (UE) 2024/1689 y RGPD

El Reglamento de Inteligencia Artificial de la Unión Europea (**AI Act**) (European Parliament, 2024) establece obligaciones diferenciadas según el nivel de riesgo. Para los modelos de IA de propósito general (*GPAI*), la normativa establece requisitos específicos:

- **Obligación de Robustez y Ciberseguridad:** Según el Artículo 15, los sistemas deben alcanzar un nivel adecuado de resiliencia frente a intentos de terceros de alterar su uso, comportamiento o funcionamiento aprovechando vulnerabilidades. Esto incluye la protección contra ataques de envenenamiento de datos (*data poisoning*) e inyecciones de prompts (*adversarial examples*).

- **Régimen Sancionador:** Es crítico distinguir las competencias. La exfiltración de datos personales (*Data Leakage*) se rige primariamente por el **RGPD** (Reglamento General de Protección de Datos), con multas de hasta el 4 % de la facturación global. Por su parte, el AI Act sanciona el incumplimiento de obligaciones de robustez o gestión de riesgos en modelos *GPAI* (Inteligencia Artificial de Propósito General) con multas de hasta 15 millones de euros o el 3 % del volumen de negocios mundial. El tope del 7 % (o 35 millones de euros) se reserva exclusivamente para la infracción de las prácticas prohibidas de IA definidas en el Artículo 5.

3.2. Responsabilidad Civil y Supervisión Humana

La implementación de un sistema de IA en producción conlleva un **deber de diligencia** operativo. El Artículo 14 del Reglamento subraya la necesidad de una **supervisión humana** efectiva, diseñada para que las personas físicas puedan vigilar el funcionamiento del sistema y prevenir o reducir al mínimo los riesgos para la salud, la seguridad o los derechos fundamentales.

Desde una perspectiva jurídica, la ausencia de un **Sistema de Gestión de Riesgos** iterativo (Artículo 9) o de mecanismos de mitigación técnica puede calificarse como negligencia. Dado que el estado de la técnica actual ofrece herramientas de supervisión y capas de filtrado, no implementar estas defensas expone a la organización a litigios por daños y perjuicios derivados de contenidos difamatorios, instrucciones peligrosas o errores financieros tras un *jailbreak*.

3.3. Integridad del Sistema y Mitigación de Sesgos

El imperativo fundamental es garantizar la integridad operativa: el sistema debe actuar única y exclusivamente para su finalidad prevista. La vulneración de este control supone un quiebre de la confianza técnica que puede derivar en:

1. **Riesgos Sistémicos y Desinformación:** En modelos de alto impacto, la pérdida de control puede facilitar la difusión masiva de contenidos generados o manipulados de forma artificial que amenacen la seguridad pública o los procesos democráticos.

2. **Amplificación de Sesgos:** La explotación de vulnerabilidades puede reactivar sesgos latentes. El Artículo 10 exige que los conjuntos de datos para el entrenamiento y prueba se sometan a prácticas de gobernanza que identifiquen y mitiguen sesgos que puedan dar lugar a discriminaciones prohibidas por el Derecho de la Unión.

4. Estrategias de mitigación técnica

La naturaleza estocástica de los LLMs impide garantizar una seguridad del 100 % mediante el entrenamiento del modelo. Por ello, la mitigación se estructura en una estrategia de **defensa multicapa**, donde se combinan técnicas internas del modelo con sistemas de supervisión externos.

4.1. Alineamiento y Seguridad Intrínseca (RLHF)

La primera línea de defensa ocurre durante el entrenamiento. El **Aprendizaje por Refuerzo a partir de la Retroalimentación Humana (RLHF)** permite alinear el modelo con directrices éticas, enseñándole a rechazar peticiones explícitamente dañinas. No obstante, esta capa es "blanda": el modelo sigue siendo vulnerable a ataques de ingeniería social o roles complejos (Jailbreak) que logran eludir las restricciones aprendidas durante el ajuste fino.

4.2. Ingeniería de Prompts Defensiva y Delimitadores

Una técnica de bajo coste computacional consiste en estructurar el *System Prompt* para endurecer la distinción entre instrucciones y datos.

- **Uso de delimitadores:** Emplear etiquetas claras (ej. `### USER INPUT ###` o etiquetas XML `<data></data>`) para encapsular la entrada del usuario. Esto ayuda al mecanismo de atención a identificar qué tokens deben tratarse como datos y cuáles como directrices de control.

- **Instrucciones de cierre:** Repetir las restricciones al final del prompt para contrarrestar el sesgo de recencia (*recency bias*), donde el modelo tiende a dar más peso a los últimos tokens de la ventana de contexto.

4.3. Arquitectura de Guardrails (El Firewall Semántico)

La solución más robusta en entornos de producción es la implementación de una capa de software externa que actúe como **proxy** entre el usuario y el LLM. Herramientas como **NeMo Guardrails** (NVIDIA, 2024) o **Llama Guard** (Inan et al., 2023) operan bajo este principio:

1. **Input Guardrails:** Antes de que la consulta llegue al LLM, un modelo de clasificación o un conjunto de reglas analiza la intención del usuario. Si se detecta un intento de inyección o contenido prohibido, la petición se bloquea o se sanitiza.

2. **Output Guardrails:** Una vez que el LLM genera una respuesta, esta es analizada antes de ser entregada al usuario. Se verifica que no contenga información sensible (fuga de PII), que el tono sea adecuado y que la información sea veraz (mitigación de alucinaciones).

4.4. Filtrado Heurístico y Modelos de Clasificación

- **Filtrado Heurístico:** Uso de listas negras de palabras clave y expresiones regulares (Regex). Aunque es rápido, es ineficaz contra ataques de ofuscación o traducciones.
- **Clasificadores Basados en Modelos:** Utilizar un segundo LLM, más pequeño y especializado (ej. Llama Guard), cuya única tarea es clasificar si una interacción es segura o no. Este enfoque es altamente efectivo pero introduce **latencia adicional** en el sistema.

Estrategia	**Ubicación**	**Ventajas**	**Limitaciones**
RLHF / Alignment	Interna	Nativa, sin latencia extra.	Fácil de eludir con Jailbreak.
Delimitadores	Prompt	Implementación inmediata.	No detiene ataques complejos.
Guardrails	Externa	Control total, configurable.	Introduce latencia y coste.
Llama Guard	Externa	Alta precisión semántica.	Requiere recursos GPU extra.

Tabla 2: Comparativa de estrategias de mitigación.

5. Parte Práctica (Prueba de Concepto)

5.1. Implementación de un agente LLM vulnerable (caso de uso simulado).

5.2. Ejecución y documentación de ataques de inyección.

5.3. Implementación de defensas (Guardrails).

5.4. Evaluación comparativa de la robustez del sistema.

6. Conclusiones

7. Referencias bibliográficas

European Parliament. (2024). Regulation (EU) 2024/1689 of the European Parliament and of the Council (Artificial Intelligence Act) [Marco legal esencial para la sección de legislación.]. *Official Journal of the European Union*. https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng

Inan, H., Jain, K., Joy, S., et al. (2023). Llama Guard: LLM-based Input-Output Safeguard for Human-AI Conversations [Referencia principal para la sección de mitigación técnica.]. *arXiv preprint arXiv:2312.06674*.

NVIDIA. (2024). *NeMo-Guardrails: Interface guidelines* [Referencia técnica citada en OWASP Top 10 for LLM Applications 2025]. GitHub. https://github.com/NVIDIA/NeMo-Guardrails

OWASP Foundation. (2024, noviembre). OWASP Top 10 for Large Language Model Applications 2025 [Estándar industrial actualizado para la taxonomía de ataques en sistemas GenAI.]. https://genai.owasp.org/llm-top-10/

Vaswani, A., Shazeer, N., Parmar, N., Uszkoreit, J., Jones, L., Gomez, A. N., Kaiser, Ł., & Polosukhin, I. (2017). Attention is All You Need [Fundamento de la arquitectura Transformer y el mecanismo de atención.]. *Advances in Neural Information Processing Systems*.